

Centro Universitário Filadélfia
Polo Salinópolis
Ciência de Dados e Inteligência Artificial

Aula 9

APIs e Segurança

Fundamentos de Propriedade Intelectual Para a Transferência de
Tecnologia de Software

Thiago Rafael da Silva Moura
trsmoura@yahoo.com.br

28 de novembro de 2025

CAPÍTULO 9

APIs e Segurança

Conectando Modelos ao Mundo Real (com Segurança)

Inicializando Sistemas...



1. Conceitos de API

O que são, REST, HTTP e JSON.



2. FastAPI

Construindo APIs modernas,
rápidas e tipadas.



3. Segurança

Auth, Criptografia e Proteção
contra Ataques.

Por que estamos aqui?

Você treinou o modelo perfeito no Jupyter Notebook.

E agora?

- > Como o aplicativo mobile vai usar seu modelo?
- > Como o site da empresa vai enviar dados para ele?

A resposta é: Envolvendo o modelo em uma API.

A Metáfora do Garçom

Cliente (Frontend): Está com fome, mas não pode entrar na cozinha.

Cozinha (Backend/Modelo): Tem os ingredientes e o talento, mas não fala com o cliente.

Garçom (API): Leva o pedido (Request) estruturado para a cozinha e traz a comida (Response) para a mesa.

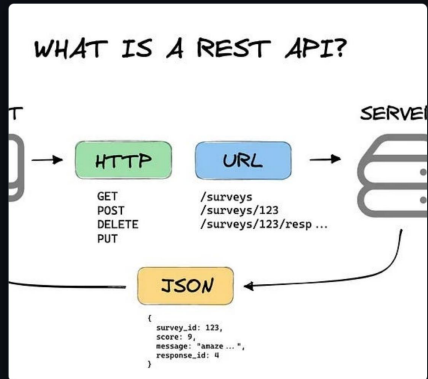


API (Application Programming Interface)

É um **contrato** entre dois softwares.

Define claramente:

- > O que você pode pedir (Endpoints).
- > Como você deve pedir (Parâmetros).
- > O que você receberá de volta (Resposta).



Arquitetura REST

REpresentational State Transfer. O padrão mais comum da web.

Stateless

O servidor não lembra do passado. Cada pedido tem tudo que precisa.

Recursos

Tudo é um recurso (ex: Usuário, Produto, Predição) acessível via URL.

Verbos HTTP

Ações padronizadas para manipular esses recursos.

Verbos HTTP

Verbo	SQL Equivalente	Uso em Data Science
GET	SELECT	Buscar metadados do modelo ou status.
POST	INSERT	Enviar dados para obter uma predição .
PUT	UPDATE	Atualizar configurações do modelo.
DELETE	DELETE	Remover um modelo antigo.

Status Codes: 0 Semáforo

2xx (Sucesso)

200 OK: Deu certo.

201 Created: Recurso criado.

4xx (Erro Cliente)

400 Bad Request: Dados inválidos.

404 Not Found: URL errada.

5xx (Erro Servidor)

500 Internal Error: Bug no seu código.

503 Unavailable: Servidor caiu.

JSON: A Língua Franca

JavaScript Object Notation.

Leve, legível por humanos e fácil de processar por máquinas.

É o formato padrão para enviar e receber dados em APIs REST.

```
{ "modelo": "random_forest_v1", "input": { "ida
```

Python Frameworks

Flask

O veterano. Simples, flexível, mas síncrono e requer extensões para tudo (validação, docs).

"Microframework clássico"

FastAPI

O desafiante moderno. Assíncrono, validação automática, documentação grátis e altíssima performance.

"O padrão para ML"

Por que FastAPI?

- > **Rápido:** Performance comparável a NodeJS e Go.
- > **Intuitivo:** Baseado em Type Hints (dicas de tipo) do Python moderno.
- > **Robusto:** Validação de dados automática com Pydantic.
- > **Padronizado:** Gera Swagger/OpenAPI automaticamente.



Hello World em FastAPI

```
from fastapi import FastAPI app = FastAPI() @app.get("/") async def raiz(): return {"mensagem": "Olá, Mundo da Cii"}
```

Rodando:

```
$ uvicorn main:app --reload
```

Decoradores de Rota

O decorador diz ao FastAPI qual URL e qual método HTTP acionam a função.

```
@app.get("/items/{id}")
```

Ler um item.

```
@app.post("/predict")
```

Criar uma predição.

```
@app.delete("/cache")
```

Limpar cache.

Pydantic: O Leão de Chácara

APIs de Data Science precisam de dados limpos. O **Pydantic** garante que os dados de entrada sigam o formato correto.

Se o cliente mandar uma string onde deveria ser um float, o Pydantic bloqueia antes mesmo de chegar na sua função.

Modelo de Dados (Schema)

Definimos uma classe herdando de BaseModel.

Usamos Type Hints para definir os campos.

```
from pydantic import BaseModel class InputModel(Base
```


Recebendo o Body

Para receber JSON no corpo do request, basta usar o modelo Pydantic como tipo do argumento.

```
@app.post("/predict") async def prever(dados: InputModelo): # 0 'dados' já é um objeto validado! features = [[dados.features[0], dados.features[1], dados.features[2], dados.features[3], dados.features[4], dados.features[5], dados.features[6], dados.features[7], dados.features[8], dados.features[9], dados.features[10], dados.features[11], dados.features[12], dados.features[13], dados.features[14], dados.features[15], dados.features[16], dados.features[17], dados.features[18], dados.features[19], dados.features[20], dados.features[21], dados.features[22], dados.features[23], dados.features[24], dados.features[25], dados.features[26], dados.features[27], dados.features[28], dados.features[29], dados.features[30], dados.features[31], dados.features[32], dados.features[33], dados.features[34], dados.features[35], dados.features[36], dados.features[37], dados.features[38], dados.features[39], dados.features[40], dados.features[41], dados.features[42], dados.features[43], dados.features[44], dados.features[45], dados.features[46], dados.features[47], dados.features[48], dados.features[49], dados.features[50], dados.features[51], dados.features[52], dados.features[53], dados.features[54], dados.features[55], dados.features[56], dados.features[57], dados.features[58], dados.features[59], dados.features[60], dados.features[61], dados.features[62], dados.features[63], dados.features[64], dados.features[65], dados.features[66], dados.features[67], dados.features[68], dados.features[69], dados.features[70], dados.features[71], dados.features[72], dados.features[73], dados.features[74], dados.features[75], dados.features[76], dados.features[77], dados.features[78], dados.features[79], dados.features[80], dados.features[81], dados.features[82], dados.features[83], dados.features[84], dados.features[85], dados.features[86], dados.features[87], dados.features[88], dados.features[89], dados.features[90], dados.features[91], dados.features[92], dados.features[93], dados.features[94], dados.features[95], dados.features[96], dados.features[97], dados.features[98], dados.features[99]]
```

Validação Automática

O que acontece se eu mandar "idade": "trinta"?

```
// Resposta automática do FastAPI (422 Unprocessable Entity) { "detail": [ { "loc": ["body", "idade"], "msg": "va
```

Você não precisa escrever nenhum if para checar tipos!

Padronizando a Saída

Assim como validamos a entrada, devemos garantir a saída.

```
class OutputPredicao(BaseModel): probabilidade: float classe: str @app.post("/predict", response_model=OutputPred:
```

Isso filtra dados sensíveis e garante que o contrato da API seja respeitado.

Swagger UI / Docs

FastAPI gera automaticamente uma página de documentação interativa em `/docs`.

Você pode testar sua API direto do navegador, sem escrever código de frontend.

✕ +

https://docs#/users

API

Users. The login logic is also here.

Get Users

Items. Items have their own docs.

Items external docs: <https://fastapi.tiangolo.com/tutorial/items/>

Get Items



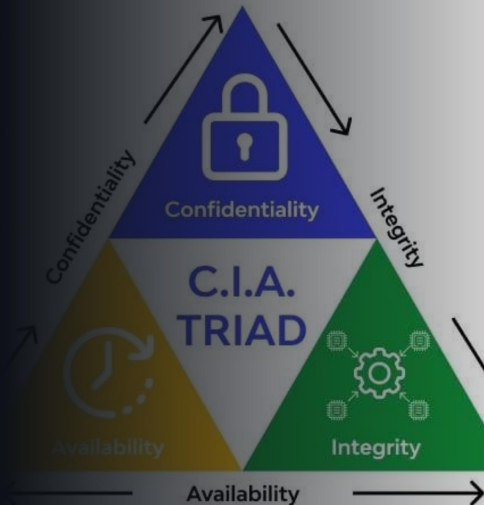
SEGURANÇA

Protegendo seus dados e modelos

A Tríade CIA

Os três pilares da segurança da informação:

- > **Confidencialidade:** Só quem deve ver, vê.
- > **Integridade:** O dado não foi alterado no caminho.
- > **Disponibilidade:** O sistema está no ar quando necessário.



AuthN vs AuthZ

Autenticação (Who?)

Verificar a identidade. "Quem é você?"

Ex: Login, Crachá, API Key.

Autorização (What?)

Verificar permissões. "O que você pode fazer?"

Ex: Admin pode deletar, User só pode ler.

HTTPS (TLS): O Carro Forte

Sem HTTPS, qualquer um na rede (Wi-Fi do café) pode ler os dados que você envia (incluindo senhas).

- > Criptografa os dados **em trânsito**.
- > Garante a identidade do servidor (Cadeado verde).
- > **Regra:** Nunca coloque uma API em produção sem HTTPS.

API Keys

O método mais simples de autenticação.

O cliente envia um segredo no Header: `X-API-Key: abc12345`.

Bom para: Automação servidor-servidor.

Ruim para: Apps frontend (fácil de roubar).



Implementando API Key

```
from fastapi.security import APIKeyHeader from fastapi import Security, HTTPException api_key_header = APIKeyHeader
```

OAuth2 e JWT

OAuth2

O padrão da indústria. Fluxos complexos para delegar acesso (ex: "Logar com Google").

JWT (JSON Web Token)

Um token assinado que contém os dados do usuário. Stateless. O servidor não precisa consultar o banco para validar.

Uso

Ideal para autenticar usuários humanos em Apps Web e Mobile.

Injection Attacks

Quando um atacante envia código malicioso em vez de dados.

```
# SQL Injection Exemplo user_input = "admin' --" query = f"SELECT * FROM users WHERE name = '{user_input}'" # Vir
```

Defesa: Nunca concatene strings em SQL. Use parâmetros (ou ORM como SQLAlchemy) e validação Pydantic.

Rate Limiting (Limitação de Taxa)

Protege contra ataques de Negação de Serviço (DoS) e força bruta.

Define um limite: "100 requisições por minuto por IP".

Se passar, retorna **429 Too Many Requests**.



CORS

Cross-Origin Resource Sharing.

Por padrão, navegadores bloqueiam requests de sites diferentes do seu API (ex: meusite.com chamando api.outrosite.com).

Você precisa configurar o CORS na API para permitir origens confiáveis.

```
app.add_middleware( CORSMiddleware, allow_origins=["https://meuapp.com"], # Lista branca allow_methods=["*"],
```

Testando a API

FastAPI fornece um `TestClient` baseado em `requests` e `pytest`.

```
from fastapi.testclient import TestClient client = TestClient(app) def test_read_main(): response = client.get("/")
```

Monitoramento e Logs

Uma API cega é um perigo. Você precisa saber:

Latência

Quanto tempo demora para responder?

Taxa de Erro

Quanto 500 estão acontecendo?

Tráfego

Quanto requests por segundo (RPS)?

Ferramentas: Prometheus, Grafana, Datadog.

Melhores Práticas

- > ✓ Use **FastAPI** para novos projetos.
- > ✓ Sempre use **Pydantic** para validar entradas.
- > ✓ Use **HTTPS** em produção.
- > ✓ Versione sua API (ex: /v1/predict).
- > ✓ Trate exceções e retorne códigos HTTP corretos.

A Arquitetura Final

1. Usuário acessa Frontend.
2. Frontend autentica e chama API via HTTPS.
3. Load Balancer distribui carga.
4. API (FastAPI) valida dados.
5. Modelo faz a predição.
6. Resposta retorna ao usuário.

Recursos Adicionais

- > **Documentação FastAPI:** fastapi.tiangolo.com (Excelente!)
- > **OWASP Top 10 API Security:** Guia de segurança.
- > **Httpie / Postman:** Ferramentas para testar APIs manualmente.



EOF (End of File)

Perguntas?

Image Sources



https://upload.wikimedia.org/wikipedia/commons/c/cc/Digital_rain_animation_medium_letters_shine.gif

Source: en.wikipedia.org



https://static.vecteezy.com/system/resources/previews/033/067/722/non_2x/waiter-serving-black-and-white-cartoon-flat-illustration-african-american-male-restaurant-server-with-tray-linear-2d-character-isolated-sommelier-catering-wedding-monochromatic-scene-image-vector.jpg

Source: www.vecteezy.com



https://miro.medium.com/1*m3JEkd9SKTK6vNPhRHCqg.jpeg

Source: medium.com



<https://fastapi.tiangolo.com/img/logo-margin/logo-teal.png>

Source: fastapi.tiangolo.com



<https://fastapi.tiangolo.com/img/tutorial/metadata/image02.png>

Source: fastapi.tiangolo.com



https://miro.medium.com/0*T-PBVB9v0Co7SYjq.jpeg

Source: medium.com
